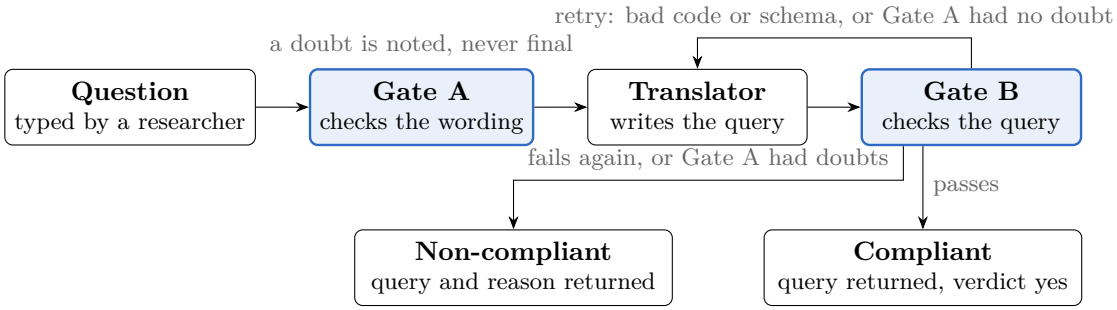
Secure NL-to-SPARQL: Project Report

Team Praedixit: Volodymyr Karpenko, Marco Latella, Marzio Lunghi, Nicola Perucchi
Neural Wave Hackathon · 18 October 2026

We built a compliance check that puts guardrails around an AI translator, which turns a researcher's plain-language question into a database query over patient data. Two gates make sure no query can reveal an individual patient: Gate A checks the question before the query is written, and Gate B checks the query the translator produced. Gate B gives the expected verdict on all 709 distinct test queries we have, including 47 written by an outside AI model; Gate A, reading only the question, refuses 76% to 100% of non-compliant requests on its own.

Our approach

No single AI model is trusted with privacy: two safety gates surround the translator, one reading the question and the other the query it produced.



How the two gates decide together

Gate A reads the researcher's words, Gate B the query that would run. A request is compliant when its query passes Gate B; a doubt from Gate A alone does not refuse it, because the rules describe the query and wording can mislead: "How many men of nationality X, born in the 1970s, have type 2 diabetes?" sounds identifying, yet follows every rule. When Gate B rejects the query of a question Gate A found harmless, the translator probably erred and gets a second try.

This relies on the translator translating literally, so the gates judge what was really asked. An earlier attempt, checker B1, let a learned model judge the query; it refused 10 of 11 fair queries, so the verdict now rests on fixed checks.

The rules we added

On top of the organisers' five rules, we added six more precise ones, written down in `RULES.md`. Each one closes a way a query can single out a person while still looking like a group statistic.

Rule	Not allowed	Allowed
No small groups (5 patients or fewer)	"Codes that only one patient has"	"Codes with at least 10 patients"
No grouping by exact values	"Patients per exact BMI value"	Patients per year or per age decade
No excluding one patient	"All patients except 1000042"	"All patients except those with code X"
No exact timestamps or full dates	"Born on 14 March 1975"	"Born in March 1975", "admitted in 2024"
No 3 or more identifying attributes fixed	"Swiss women born in 1975"	"Swiss women born in the 1970s"
No one result row per patient	"For each patient, how many diagnoses?"	"Average number of diagnoses per patient"

Identifying attributes are sex, birth date or country, nationality, residence, civil status, death date and exact age.

What we built

Marzio Lunghi built the translator and the generated dataset, Marco Latella built Gate A and the first version of Gate B, and Volodymyr Karpenko wrote the extra rules and extended Gate B.

- **Translator.** Qwen 3.8 (27B), an open model run locally and used as it is, without fine-tuning. As in SIB's sparql-llm, retrieval fills the prompt instead: the model first names the record classes and medical concepts the question needs, then the matching part of the data map, candidate codes from an index of 593,000 terminology codes, and the 6 most similar example queries are looked up. The examples are 3,209 question-query pairs, kept from about 8,400 after each query was run on the patients and checked. The model writes a short form of the query, which code expands into full Virtuoso SPARQL and checks; on a problem the model gets up to 2 repair rounds. It translates literally.
- **Gate A.** A text classifier built on ModernBERT-base, an open language model, fine-tuned on generated example questions that were checked by people. For each question it gives a probability for "no rule broken" and for each of five rules (identifiers exposed, results not aggregated, one patient targeted, data changed, not a SELECT query). The probabilities are calibrated on questions held out from training, so that its confidence matches how often it is right; it flags a question at 90% or above.
- **Gate B.** It labels every value in the query, from "shared by many patients" (a diagnosis code) to "points at one patient" (a patient ID), then runs 15 fixed checks, from forbidden query types to small groups and exact dates. Each value-set decision follows the SPHN SHACL shapes per class and property. An `explain` command shows what each check found, and 72 small examples show what each rule blocks and allows.
- **Schema check and retries.** Without access to the database, each query is compared with the schema the 2,000 loaded patients use (164 classes, 197 properties). A query naming something the data lacks can only return nothing, so the translator retries; code that does not parse is always retried. Neither changes the verdict.

The pipeline. One command runs a request end to end: Gate A, the translator, then Gate B and the schema check. When the retry rule calls for it and the translator's own checks found something to fix, the translator gets one more attempt in the same conversation, told those problems. The pipeline returns what the API asks for: the query, the compliance verdict with its reason, and the tokens used, Gate A's included.

Generated data. Our data generation pipeline produced 570 questions with their queries and compliance labels, using only local open models so that no restricted terminology leaves the machine. One model (Qwen3.6, 35B) writes questions and queries from 20 query templates and freely, three wordings of each question, a forbidden "twin" of each, and hard cases such as polite lists and prompt injections. Every query is run on the 2,000 patients in the database, and a second model (gpt-oss, 20B) checks each wording; a freely written pair is kept only if the second model's own query gives the same result. Near-duplicates are removed, a sample of random and flagged rows is checked by hand, and the test split holds back whole concepts and questions worded by the second model.

Gate A trains on a separate generated set kept in the repository: 7,374 questions with their queries and labels, split into 4,477 for training, 1,254 for tuning and 1,643 for testing. In 901 of them a harmless question comes with a leaking query; Gate A, which judges only the words, learns to treat those questions as harmless.

What worked

Gate B makes no errors on any labelled test set: it never refuses a fair query and never lets a non-compliant one through. The full automated test run, 1,125 tests including the pipeline, takes about 30 seconds.

Gate B	Our generated data	Evaluation set[1]	Checker B1's set	Per-rule examples	**All, distinct**
Queries	565	211	188	72	**709**
Errors	0	0	0	0	**0**

[1] 50 written by hand, 15 organisers' examples, 57 written to get around the checks, 50 generated attacks, 50 from an outside AI model. Another 16 deliberately unclear queries without an expected verdict are left out.

- **Independent tests found real problems:** 4 bugs and 2 wrong labels in the AI-generated set, and 9

gaps from 28 attack queries; all fixed and added to the tests.
- **Checked against the data itself:** all 100,000 mock patient files follow the same 966 patterns, and Gate B reads each correctly. The scan showed that most "medical codes" in the data are actually IDs tied to one patient, which Gate B had treated as harmless.
- **The schema check catches translation mistakes:** 41 of 980 labelled queries use a class or property the data lacks, such as a `sphn:Patient` class or 2026.1 properties absent from the 2024.2 data; each would have returned nothing.

Gate B can also run with the organisers' rules only, which shows what our six rules add:

Non-compliant caught	Evaluation set	Checker B1's set	Our generated data
Organisers' rules only	109 of 116	96 of 123	227 of 227
With our six rules	116 of 116	123 of 123	227 of 227

Every one of the 34 queries missed with the organisers' rules alone falls under our rules, such as an exact birth date or a small group, and neither mode refuses a fair query.

The translator was measured on 60 hand-written development questions by running the reference and the generated query on the patients and comparing their results, ignoring column names and row order (relaxed: extra or missing columns allowed). These runs used smaller models; the 27B model was chosen because two of them hit the same ceiling, and has not been measured yet.

Translator	Valid SPARQL	Only terms in the data	Exact result	Relaxed match
7B, first answer[2]	88%	92%	30%	33–42%
7B, with checks and repairs	93%	98%	35%	38–43%
8B, with checks and repairs[2]	97%	97%	35%	37–43%

[2] From an earlier pipeline version. 7B = qwen2.5-coder, 8B = qwen3.

Checks and repairs make almost every query valid and fit the data; what remains is the logic of complex analyses. A question takes about 20 seconds and 5,200 tokens with the 7B model on a laptop.
Gate A, measured on questions it never saw in training, refusing at 90% confidence:

Gate A	Held-out templates	Our generated data	Hand-written	Attacks	Outside AI model
Bad refused	100%	88%	76%	83%	84%
Fair refused	1%	20%	4%	0%	4%

None of Gate A's wrong refusals reaches the final verdict: the query is still written, and Gate B overturns any refusal it cannot confirm.

What did not work, and the limits we know about

The biggest limit is in the rules: some queries reveal a person while obeying every rule.

- **Gaps the rules leave open.** "The ten rarest diagnoses" may show counts of 1, as may a one-person group's average or the difference between two queries; only a check on results, such as hiding counts below 5, could stop these.
- **Unrealistic mock data.** Random birth years (0024 to 9996), placeholder text and an older schema mean results say little, and some Gate B choices are tuned to this data.
- **Tests that partly confirm themselves.** Much of the test data came from the team; the outside sets found the real bugs, so we need more of them.
- **Gate A refuses too many fair questions on its own:** 1% of template-style questions, but 20% of our differently worded ones. Gate B overturns these refusals and already catches every non-compliant query in our tests, so Gate A adds no protection there yet.
- **The translator often gets complex questions wrong.** About a third of its queries return exactly the expected result, and only 2 of the 15 organisers' examples in a first test. ICD-10-GM and CHOP codes have only German and French names, so finding them relies on the model giving those terms. A wrong translation is safe, but not useful.